

ULAGAT

Максимально полная техническая документация

Максимально полная техническая база проекта

Единый исчерпывающий документ: архитектура, весь стек, все 11 модулей платформы, полная модель данных (30 таблиц), все 21 server actions с деталями реализации, все 13 API endpoints, 82 компонента, полный DevSecOps аудит по блокам (RLS, rate-limit, MFA, CSP, шифрование, SCA), примеры реального кода из репозитория, миграции, окружение и roadmap.

<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Документ' 'frags': [ParaFrag(_tag_='para', bold=1, fontName='Noto-Bold', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='Документ', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>	<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Максимально полная техническая документация Ulagat' 'frags': [ParaFrag(_tag_='para', bold=0, fontName='Noto', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='Максимально полная техническая документация Ulagat', textColor=Color(.058824,.090196,.164706,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>		
<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Версия' 'frags': [ParaFrag(_tag_='para', bold=1, fontName='Noto-Bold', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='Версия', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>	<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': '3.0.0' 'frags': [ParaFrag(_tag_='para', bold=0, fontName='Noto', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='3.0.0', textColor=Color(.058824,.090196,.164706,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>	<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Дата' 'frags': [ParaFrag(_tag_='para', bold=0, fontName='Noto', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='Дата', textColor=Color(.058824,.090196,.164706,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>	<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': '7 июля 2026 г.' 'frags': [ParaFrag(_tag_='para', bold=0, fontName='Noto', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='7 июля 2026 г.', textColor=Color(.058824,.090196,.164706,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>
<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Объём' 'frags': [ParaFrag(_tag_='para', bold=1, fontName='Noto-Bold', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='Объём', textColor=Color(1,1,1,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>	<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': '~50+ страниц' 'frags': [ParaFrag(_tag_='para', bold=0, fontName='Noto', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='~50+ страниц', textColor=Color(.058824,.090196,.164706,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>	<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Статус' 'frags': [ParaFrag(_tag_='para', bold=0, fontName='Noto', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='Статус', textColor=Color(.058824,.090196,.164706,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>	<pre>Paragraph('caseSensitive': 1 'encoding': 'utf8' 'text': 'Конфиденциально' 'frags': [ParaFrag(_tag_='para', bold=0, fontName='Noto', fontSize=7.3, greek=0, italic=1, link=[], rise=0, text='Конфиденциально', textColor=Color(.058824,.090196,.164706,1), us_lines=[])] 'style': 'bulletText': None 'debug': 0) #Paragraph</pre>

ULAGAT

Максимально полная техническая документация

Единственный источник правды по проекту — заменяет все предыдущие версии документации и security-аудита.

ULAGAT

Максимально полная техническая документация

Оглавление

- 1. Обзор проекта и бизнес-контекст
- 2. Технологический стек (полный)
- 3. Роли и матрица доступов (полная)
- 4. Функции платформы — 11 модулей (детально)
- 5. Модель данных — 30 таблиц с полями
- 6. Server Actions — все 21 с сигнатурами и логикой
- 7. API Endpoints — все 13 маршрутов
- 8. React компоненты — 82 штуки по модулям
- 9. Хуки и утилиты (lib/*)
- 10. TypeScript типы
- 11. DevSecOps аудит — Блок 0: модель угроз
- 12. DevSecOps аудит — Блок 1: Supabase/БД
- 13. DevSecOps аудит — Блок 2: Vercel/Edge/API
- 14. DevSecOps аудит — Блок 3: безопасность будущего ИИ
- 15. DevSecOps аудит — Блок 4: аутентификация и MFA
- 16. DevSecOps аудит — Блок 5: цепочка поставок и мониторинг
- 17. Реальный код: примеры из репозитория
- 18. Миграции БД и переменные окружения
- 19. Чек-лист перед релизом и roadmap
- 20. Обновления (июль 2026): лента, СКУД, push, CSP enforce

ULAGAT

Максимально полная техническая документация

1. Обзор проекта и бизнес-контекст

Ulagat — Campus OS для школы BINOM (Астана, Казахстан). Веб-платформа, которая заменяет разрозненные чаты (WhatsApp) и бумажный документооборот единой средой для учеников, родителей, учителей и администрации.

Ключевое ограничение и дизайн-решение:

В школе телефоны учеников конфискуются на весь учебный день. Это продиктовало двухфазную модель потребления интерфейса:

- **Утренний режим (5–10 минут, мобильный, до сдачи телефона):** компактный layout, только расписание на сегодня, замены, закреплённые объявления, виджет текущего урока.
- **Вечерний / полный режим (15–40 минут, десктоп/дома):** весь функционал — все 11 модулей доступны, десктоп-оптимизированный layout.
- Реализовано через useUIPhase() хук: автоматически по времени суток (6:00–8:30 = утро) или ручное переключение с сохранением в localStorage.

Что уже построено:

- Аутентификация (email/пароль через Supabase Auth), профили с 6 ролями
- Маркетплейс услуг (доска объявлений), события с регистрацией
- Репутационный лидерборд с верификацией достижений
- Друзья/личные сообщения/групповые чаты
- Административная панель с модерацией контента
- Архив олимпиадных материалов
- Реальная генерация PDF-справок с кириллицей/казахским текстом
- Полная безопасность: rate-limiting, MFA (TOTP), CSP, структурные логи

Статус на 5 июля 2026 г.:

- Функциональность готова, безопасность проверена живыми атаками
- Интерфейс полностью готов (десктопный сайдбар, мобильные вкладки, тёмная тема)
- Локализация: русский (по умолчанию), казахский, английский — 200+ ключей
- Пилотная стадия: наполнение данными школы (расписание, роли персонала)
- Операционные блокеры: домен Resend не верифицирован, SUPABASE_SERVICE_ROLE_KEY нужно добавить в Vercel

2. Технологический стек (полный)

2.1 Основные зависимости

Пакет	Версия	Назначение
Next.js	16.2.10	SSR, App Router, Server Actions, Middleware (Edge Runtime)
React	19.2.3	UI-библиотека, Server Components
TypeScript	5.x	Строгая типизация, noImplicitAny
Tailwind CSS	4.x	Utility-first стили + тёмная тема (dark:)
@supabase/supabase-js	2.93.3	Клиент Postgres + Auth + Storage + Realtime
@react-pdf/renderer	4.5.1	Серверная генерация PDF справок (JSX PDF)
Resend	6.x	Транзакционные email (замены, объявления, справки)
Stripe	20.x	Оплата услуг, подписки premium
@upstash/ratelimit	2.0.8	Sliding-window rate limiting на Edge
@upstash/redis	1.x	REST-клиент Redis для лимитера
Framer Motion	12.x	Анимации, scroll-reveal эффекты
shadcn/ui + Radix UI	—	Доступные примитивы компонентов (Dialog, Select, Toast)

2.2 Инфраструктура и деплой

- **Vercel:** хостинг фронтенда, автодеплой при пуше в main, Edge Middleware, Vercel Cron Jobs
- **Supabase:** managed Postgres + GoTrue (auth) + Storage (файлы) + Realtime
- **Upstash:** serverless Redis (REST API) для rate-limiting — работает в любом рантайме без TCP-соединения
- **Часовой пояс:** Asia/Almaty (UTC+5) — канонический для ВСЕХ дата/время операций через lib/schedule/almaty-time.ts

3. Роли и матрица доступов (полная)

Роль	Кто	Как получить
student	Ученик 5–11 класс	Регистрация (по умолчанию)
teacher	Учитель	Назначает admin
parent	Родитель	Регистрация через инвайт-код от ученика (6-значный, TTL 24ч)
parliament	Школьный парламент/актив	Назначает admin из student
moderator	Завуч / вице-директор	Назначает admin
admin	Супер-администратор	Только вручную в БД

Полная матрица прав по функциям:

Функция	student	parent	parliament	mod/admin
Просмотр расписания/объявлений				
Ввод расписания/замен				
Публикация объявлений				
Создание событий				
Одобрение событий/материалов				
Загрузка достижений				
Верификация достижений				
Создание/управление клубом				
Публикация потеряшки				
Верификация потеряшки				
Запрос справки				
Одобрение справки (PDF)				
Просмотр СКУД своего ребёнка				
Управление ролями				admin only

ULAGAT

Максимально полная техническая документация

4. Функции платформы — 11 модулей (детально)

4.1 Расписание и замены

Динамическое квартальное расписание по классам (grade + class_letter). Moderator/admin вводят через сетку класс×день×урок. При создании замены/отмены урока — email рассылка всем ученикам класса + их родителям (через family_bonds). Виджет текущего урока показывает subject/teacher/room + countdown до звонка. Проверка на прошедшую дату (almatyTodayIso()) и на воскресенье (не учебный день).

4.2 Официальные объявления

Категории: медосмотр, линейка, важное, общее. Таргетинг по классам (target_grades: number[] | null). Пин-флаг для закрепления сверху ленты. Дата истечения (expires_at, конвертируется в конец дня Almaty). Email при публикации, notified_at штампуются после успешной отправки.

4.3 События и олимпиады

Афиша с регистрацией участников (публичный список — делегация). Архив олимпиад: учителя/parliament загружают PDF-материалы, фильтр по сложности/году. Cron-задача (Vercel Cron) отправляет email-напоминания за 24ч до дедлайна регистрации.

4.4 Клубы

Каталог активных клубов с категориями (#it, #sport, #debates). Страница клуба: описание, участники, встречи. Лидер клуба (parliament) отмечает посещаемость на встречах. Лидерборд клубов: очки за встречи (+5), за участников (+1 каждый), за достижения членов.

4.5 Репутация и лидерборд

Ученики загружают дипломы/сертификаты (achievements, статус pending). Parliament/staff верифицирует начисляются очки по тирам: школьный (+10), городской (+50), республиканский/международный (+150). Приватность: переключатель анонимности заменяет имя на случайный псевдоним («Анонимный Лев»).

4.6 Потеряшки (Lost & Found)

Публикация потерянной/найденной вещи с фото, категорией, местом. Кнопка «Это моё!» создаёт заявку (audit log для защиты от мошенничества). Parliament/moderator верифицирует статус «Найдено» уведомление всем, кто кликнул «Это моё».

4.7 Доска объявлений (Services)

Категории: репетиторство, помощь с проектами, доп. курсы, стажировки. Публикуют ученики/parliament, одобряет staff. Срок действия объявления настраиваемый (3/5/7/10 дней).

4.8 Профориентация (ЕНТ)

Персональный трекер: баллы ЕНТ по предметам (ent_scores JSONB), целевые вузы с проходными баллами прошлых лет (target_universities JSONB[]), дедлайны грантов с countdown. Калькулятор доступных специальностей при текущих баллах.

4.9 Справки из школы (PDF-генератор)

4 типа: enrollment (с места учёбы), grades (об успеваемости), attendance (о посещаемости), character (характеристика). Флоу: student requestCertificate() staff review approveCertificate() рендерит PDF через

ULAGAT

Максимально полная техническая документация

@react-pdf/renderer с шапкой BINOM загрузка в приватный Storage bucket 5-минутная подписанная ссылка на скачивание. Один pending-запрос на тип одновременно (partial unique index).

4.10 Общение

Личные сообщения (DM), групповые чаты, система друзей (заявки pending/accepted). Создание разговора проверяет дубликаты через /api/conversations/start.

4.11 Настройки и безопасность

Язык (ru/kk/en), тема (light/dark/system), включение TOTP MFA (только staff), приватность в лидерборде.

ULAGAT

Максимально полная техническая документация

5. Модель данных — 30 таблиц с полями

5.1 Пользователи и связи

- **profiles:** id, email, full_name, role, grade, class_letter, phone, avatar_url, leaderboard_anonymous, external_skud_id
- **family_bonds:** id, parent_id, student_id, created_at — UNIQUE(parent_id, student_id)
- **parent_invite_tokens:** id, token (6-значный), student_id, expires_at (+24ч), used_at

5.2 Расписание

- **schedule:** id, grade, class_letter, day_of_week (1-7), period (1-8), subject, teacher_id, room, valid_from/until
- **substitutions:** id, schedule_id, date, grade, class_letter, period, type ('substitution' | 'cancellation' | 'room_change'), subject, substitute_teacher_name, room, note, notified_at

5.3 Коммуникации

- **announcements:** id, title, body, category, target_grades[], pinned, expires_at, notified_at
- **conversations, messages, groups, group_messages:** личные и групповые чаты

5.4 События и клубы

- **events, event_registrations:** афиша с тегами и регистрацией
- **study_materials:** архив олимпиад (PDF attachments)
- **clubs:** id, name, category, leader_id, points, status
- **club_members, club_meetings:** участники, посещаемость (attendees UUID[])

5.5 Репутация и сервисы

- **achievements:** статус pending/verified, тип (school/city/republic), очки
- **services:** доска объявлений с категориями и сроком действия
- **lost_items, lost_item_claims:** статус lost/found/claimed + audit заявок
- **certificates:** id, user_id, type, purpose, status (pending/approved/rejected/ready), pdf_path, rejection_reason, processed_by, processed_at

5.6 Прочее

- **career_tracker:** ent_scores JSONB, target_universities JSONB[]
- **subscriptions:** plan (free/premium), stripe_subscription_id
- **ai_usage:** лимиты ИИ-функций (инфраструктура на будущее, ИИ пока не подключен)
- **skud_events:** турникет: external_id, direction (in/out), gate, recorded_at

Все 30 таблиц защищены Row Level Security с force row level security — политики применяются даже к владельцу таблицы.

ULAGAT

Максимально полная техническая документация

6. Server Actions — все 21 с сигнатурами и логикой

Все действия используют паттерн: **auth check isUuid валидация RLS проверка БД мутация revalidatePath**. Привилегированные действия дополнительно требуют AAL2 (mfaStepUpRequired).

6.1 Сертификаты (app/certificates/actions.ts)

- **requestCertificate(type, purpose):** валидирует enum + длину purpose (300 симв), проверяет отсутствие открытого запроса того же типа (count-check + partial unique index как страховка от гонки), INSERT с user_id=auth.uid()
- **approveCertificate(id):** requireStaff() + MFA, загружает cert+requester профиль, рендерит PDF (renderCertificatePdf), генерирует docNumber вида SPR-2026-XXXXXX, загружает в приватный bucket через admin-клиент, UPDATE status='ready' с .eq('status','pending') race-guard, отправляет email (non-fatal при ошибке)
- **rejectCertificate(id, reason):** требует причину (500 симв), тот же race-guard на статус
- **getCertificateDownloadUrl(id):** RLS-scoped SELECT (видит свои или staff видит все), проверка что pdf_path соответствует канонической схеме user_id/cert_id.pdf (защита от подмены пути), createSignedUrl на 5 минут с download-заголовком

6.2 Объявления (app/announcements/actions.ts)

- **createAnnouncement(input):** requireStaff+MFA, валидация title(200)/body(5000)/category enum, target_grades дедуп+сортировка (1-11), expires_at конвертируется в конец дня Almaty (+05:00), email-рассылка, notified_at штамп
- **deleteAnnouncement(id):** requireStaff+MFA

6.3 Замены (app/schedule/substitutions/actions.ts)

- **createSubstitution(input):** requireStaff+MFA, ISO_DATE regex, отклоняет прошедшие даты (< almatyTodayIso()), проверка воскресенья (isoDayOfWeek===7), grade 1-11, period 1-8, type enum, требует subject/teacher для substitution и room для room_change, ловит 23505 (дубликат класс+дата+урок)
- **deleteSubstitution(id):** requireStaff+MFA

6.4 Расписание (app/schedule/manage/actions.ts)

- **upsertScheduleCell(grade, class_letter, day_of_week, period, subject, teacher, room, dates):** moderator/admin only+MFA

6.5 Админ (app/admin/actions.ts, app/admin/users/actions.ts)

- **updateUserRole(userId, newRole):** requireAdmin+MFA — только admin меняет роли
- **approveService/Event/Material(id) / rejectService/Event/Material(id, reason):** checkPermission()+MFA, модерация контента

6.6 Профиль и прочее

- **updateProfile(data), generateParentInviteCode()** — 6-значный код, TTL 24ч
- **createClub/deleteClub/joinClub/leaveClub**
- **uploadAchievement/verifyAchievement/rejectAchievement**

ULAGAT

Максимально полная техническая документация

- `createLostItem/claimLostItem/verifyLostItem`
- `sendMessage/createConversation/addFriend`

7. API Endpoints — все 13 маршрутов

Route	Описание
POST /api/auth/signout	Выход: очищает session, редирект /login
POST /api/checkout	Stripe: создание checkout session (priceId URL)
POST /api/subscriptions/checkout	Stripe subscriptions (premium план)
GET /api/subscriptions/portal	Редирект на Stripe customer portal
POST /api/webhooks/stripe	Webhook: проверка stripe-signature, обновляет subscription статусы
POST /api/conversations/start	Создание DM с проверкой дубликатов
POST /api/friends	Отправка запроса в друзья (friendships.pending)
POST /api/groups	Создание группового чата
POST /api/events/register	Регистрация на событие
POST /api/achievements	Загрузка диплома (статус pending)
GET /api/users/search	Поиск по email/имени {id, full_name, grade, class}
POST /api/cron/event-reminders	Vercel Cron (ежедневно): напоминания за 24ч
POST /api/csp-report	CSP violation reports от браузера stdout Vercel

Webhook Stripe обязан проверять подпись stripe-signature через stripe.webhooks.constructEvent() — критичный API-рубеж, реализовано.

ULAGAT

Максимально полная техническая документация

8. React компоненты — 82 штуки по модулям

Сертификаты: CertificateRequestForm, DownloadCertificateButton, CertificateReviewTable, CertificateStatusBadge

Расписание: WeekGrid, CurrentLessonWidget, SubstitutionBadge, ScheduleManageGrid

Объявления: AnnouncementForm, AnnouncementCard, AnnouncementList, CategoryBadge

События: EventCard, DelegationList, CountdownWidget, EventRegisterButton

Клубы: ClubCard, AttendanceTable, ClubLeaderboard, ClubMeetingForm

Лидерборд: LeaderboardTable, AchievementUpload, PrivacyToggle, TierBadge

Потеряшки: LostItemCard, ClaimButton, ClaimsModal, LostItemForm

Профиль: ProfileCard, EditProfileForm, InviteCodeGenerator, AttendanceLog

Профориентация: ENTCalculator, UniversityComparison, CareerGoalsForm

Навигация: Sidebar (десктоп), NavBar (мобильный верх), MobileTabBar (низ)

MFA/Безопасность: MfaSection (settings), MfaChallengeForm, QrCodeDisplay

UI/Общие: ThemeToggle, LanguageSelect, LoadingSpinner, Badge, Button, Modal, Toast

ULAGAT

Максимально полная техническая документация

9. Хуки и утилиты (lib/*)

Хуки:

- **useT():** перевод текущего языка, t(key) функция из словарей ru/kk/en
- **useProfile():** профиль текущего пользователя (full_name, role, grade, class_letter)
- **useUIPhase():** режим интерфейса (morning | full) по времени Almaty или ручной toggle

Утилиты безопасности (lib/security/*):

- **mfa.ts — mfaStepUpRequired(supabase):** проверяет AAL2 через supabase.auth.mfa.getAuthenticatorAssuranceLevel(). Возвращает true только если nextLevel==='aal2' И currentLevel!=='aal2'. Fails OPEN при ошибке GoTrue (RLS остаётся главным рубежом)
- **rate-limit.ts — checkAuthRateLimit(request):** sliding window 10/60сек по IP через @upstash/ratelimit. Полностью выключен без env-переменных (UPSTASH_REDIS_REST_URL/_TOKEN отсутствуют allowed:true всегда)
- **csp.ts — buildCsp(nonce):** собирает CSP policy, script-src с nonce+strict-dynamic, connect-src разрешает Supabase REST+WSS, сейчас Report-Only

Прочие утилиты:

- **validation.ts:** isUuid(value) — regex-проверка UUID перед подстановкой в SQL
- **schedule/almaty-time.ts:** almatyNow(), almatyTodayIso() — фиксированный сдвиг UTC+5
- **pdf/certificate.tsx:** renderCertificatePdf(data) Buffer, clean() фильтрует control-символы посимвольно через codePointAt()
- **notifications/*.ts:** notifySubstitution, notifyAnnouncement, notifyCertificateProcessed — Resend API, fail-safe (мутация проходит даже если email не ушёл)
- **i18n/ru.ts, kk.ts, en.ts:** 200+ ключей, включая mfa.* namespace (22 ключа для UI 2FA)

10. TypeScript типы (types/index.ts)

Тип	Определение
UserRole	'student' 'teacher' 'parent' 'parliament' 'moderator' 'admin'
CertificateType	'enrollment' 'grades' 'attendance' 'character'
CertificateStatus	'pending' 'approved' 'rejected' 'ready'
SubstitutionType	'substitution' 'cancellation' 'room_change'
AnnouncementCategory	'medical' 'assembly' 'important' 'general'
Certificate	{id, user_id, type, purpose, status, pdf_path, rejection_reason, processed_by, created_at, processed_at}
Profile	{id, email, full_name, role, grade?, class_letter?, phone?, leaderboard_anonymous, avatar_url}
Subscription	{id, user_id, plan, expires_at, stripe_subscription_id}
Announcement	{id, title, body, category, target_grades, pinned, created_by, expires_at, notified_at}

ULAGAT

Максимально полная техническая документация

11. DevSecOps аудит — Блок 0: модель угроз

Стек: Next.js 16 (App Router) на Vercel + Supabase (Postgres/GoTrue/Storage) + Stripe. Мы Serverless/BaaS — классический «периметр сервера» (Nginx/Slowloris/TLS-конфиг) нам не принадлежит, им управляют Vercel и Supabase.

Реальная поверхность атаки:

- **БД напрямую через PostgREST** (anon-ключ публичен) единственный рубеж это RLS. Это наш главный фронт.
- **Server Actions / Route Handlers** — POST-запросы напрямую, минуя UI-проверки.
- **Middleware** — редиректы по роли/AAL2 для навигации по страницам, но НЕ для прямых POST на server actions.

Легенда статусов в аудите: [OK] — уже реализовано и проверено; [PATCH] — применён патч; [DASHBOARD] — требует настройки в панели Supabase/Vercel; [N/A] — неприменимо к нашей архитектуре.

ULAGAT

Максимально полная техническая документация

12. DevSecOps аудит — Блок 1: Supabase и защита данных

1.1 RLS против IDOR/BOLA — главный рубеж [OK]

Анон-ключ публичен, любой может дёргать PostgREST напрямую, минуя фронт и middleware. Проверено живыми атаками:

- **profiles UPDATE** имеет `with_check`, который пиннит `role` и `external_skud_id` к текущим значениям — самоэскалация роли и подмена СКУД на своей строке невозможны; `qual (auth.uid() = id)` режет чужие строки.
- **substitutions/certificates** — аналогичный паттерн: `qual` режет чужие строки, `with_check` фиксирует неизменяемые поля.

Канонический шаблон безопасной таблицы (копировать для новых таблиц):

```
alter table public.some_entity enable row level security;
alter table public.some_entity force row level security;

create policy "own_select" on public.some_entity
  for select using (auth.uid() = user_id);

create policy "own_insert" on public.some_entity
  for insert with check (auth.uid() = user_id and status = 'pending');

create policy "staff_all" on public.some_entity
  for all using (
    exists (select 1 from profiles
            where id = auth.uid() and role in ('admin','moderator'))
  );
```

Регулярная проверка (CI или вручную): таблиц без RLS быть не должно.

```
-- ##### 0 #####:
select relname from pg_class
where relkind = 'r' and relnamespace = 'public'::regnamespace
and not relrowsecurity;
```

1.2 Adversarial-тест RLS (после каждой миграции политик) [OK]

Безопасный приём: DO-блок с `set_config('request.jwt.claims', ...) + SET LOCAL role authenticated`, серия атак, `RAISE EXCEPTION` в конце — транзакция откатывается, ничего не персистится.

```
DO $$
DECLARE v_student uuid := (select id from profiles where role='student' limit 1);
BEGIN
  PERFORM set_config('request.jwt.claims',
    json_build_object('sub', v_student, 'role','authenticated')::text, true);
  SET LOCAL role authenticated;

  -- ##### 1: ##### admin
  BEGIN
    UPDATE profiles SET role='admin' WHERE id = v_student;
    RAISE EXCEPTION 'FAIL: self -> admin should be BLOCKED';
  EXCEPTION WHEN insufficient_privilege OR others THEN
    RAISE NOTICE 'OK: self -> admin BLOCKED';
  END;

  -- ##### 2: ##### approved-#####
  IF (SELECT count(*) FROM certificates WHERE user_id != v_student) > 0 THEN
    RAISE EXCEPTION 'FAIL: other -> certificates rows > 0';
  END IF;
  RAISE NOTICE 'OK: other -> certificates rows=0';
  RAISE EXCEPTION 'rollback (test only, no persist)';
END;
```

ULAGAT

Максимально полная техническая документация

```
END $$;
```

Ожидаемо: selfadmin BLOCKED, othercertificates rows=0. Именно это и наблюдали.

1.3 Service Role Key vs Anon Key [OK]

- **SUPABASE_SERVICE_ROLE_KEY** обходит RLS. Живёт только в `lib/supabase/admin.ts` (`createAdminClient`), импортируется исключительно из `Server Actions/Route Handlers/Server Components`. `autoRefreshToken:false`, `persistSession:false`. Никогда не в клиентском бандле, никогда не в `NEXT_PUBLIC_*`.
- **NEXT_PUBLIC_SUPABASE_ANON_KEY** публичен по дизайну, ограничен RLS-политиками на каждый запрос.

1.4 Шифрование PII — честная инженерная оценка [PATCH, точно]

Supabase шифрует at-rest (AES-256) и in-transit (TLS). Пароли/email в `auth.users` под GoTrue, недоступны через наши таблицы. Наш PII в `profiles`: `full_name`, `grade`, `class_letter`, `avatar_url`, `external_skud_id`.

Column-level шифрование через `pgcrypto` ломает `where/индексы/order by`. Для имён и класса, которые нужны в фильтрах и `join-ax` (адресация замен по `grade+class_letter`), это вредно — теряется RLS-фильтрация и производительность. Поэтому шифруем точно только то, что (а) действительно чувствительно и (б) не участвует в фильтрах.

Кандидат — `external_skud_id` (идентификатор турникета) через Supabase Vault:

```
create extension if not exists supabase_vault;
```

```
-- #####, ##### Vault, ## #####
```

```
select vault.create_secret('skud-encryption-key', gen_random_uuid()::text);
```

Пост-квантовая криптография [N/A]: гибридный обмен ключами (X25519MLKEM768) — дефолт TLS-терминации Vercel/Cloudflare Edge с 2025 г. На уровне нашего кода PQС внедрять нечего.

ULAGAT

Максимально полная техническая документация

13. DevSecOps аудит — Блок 2: Vercel / Edge — API и сеть

2.1 Rate Limiting на Edge [ОК, реализовано]

Анти ИИ-брутфорс, анти-парсинг, анти credential-stuffing. Так как своего сервера нет, лимитируем в middleware.ts на Edge через распределённый счётчик Upstash Redis.

```
// lib/security/rate-limit.ts
const authLimiter = redis ? new Ratelimit({
  redis,
  limiter: Ratelimit.slidingWindow(10, "60 s"),
  prefix: "rl:auth",
}) : null;

export async function checkAuthRateLimit(request) {
  if (!authLimiter) return { allowed: true, retryAfterSeconds: 0 };
  const { success, reset } = await authLimiter.limit(clientIp(request));
  return { allowed: success, retryAfterSeconds: ... };
}
```

Гейт на env: без ключей (UPSTASH_REDIS_REST_URL/_TOKEN) лимитер полностью отключён (allowed:true всегда) — приложение никогда не падает из-за отсутствия Redis-аккаунта. При ошибке Upstash — fail open (доступность школьной платформы важнее строгости).

2.2 Заголовки безопасности и CSP [ОК частично + готово к enforce]

Уже стоят в next.config.ts: Strict-Transport-Security (2 года, includeSubDomains, preload), X-Frame-Options: SAMEORIGIN, X-Content-Type-Options: nosniff, Referrer-Policy.

CSP — nonce-based через middleware (статический CSP ломает inline-скрипты Next):

```
// lib/security/csp.ts
export function buildCsp(nonce) {
  return [
    `default-src 'self'`,
    `script-src 'self' 'nonce-${nonce}' 'strict-dynamic'`,
    `style-src 'self' 'unsafe-inline'`,
    `img-src 'self' blob: data: https:`,
    `connect-src 'self' ${supabaseUrl} ${supabaseWs}`,
    `frame-ancestors 'self'`,
    `object-src 'none'`,
    `report-uri /api/csp-report`,
  ].join('; ');
}
```

Внедрено поэтапно: сначала Content-Security-Policy-Report-Only + отчёты на /api/csp-report, чтобы убедиться что ничего не сломалось (Stripe, Supabase realtime, картинки). Переключение в enforce — удаление суффикса '-Report-Only', одна строка.

Дополнительно применено: Permissions-Policy, X-Permitted-Cross-Domain-Policies, Cross-Origin-Resource-Policy.

2.3 CORS [N/A/ОК]

Приложение same-origin: фронт дёргает свои же роуты того же домена. Отдельный CORS не нужен и не настроен — это правильно (нет Access-Control-Allow-Origin: *). Webhook Stripe обязан проверять подпись stripe-signature — это не CORS, но критичный API-рубеж, реализовано.

2.4 Env-переменные в Vercel [DASHBOARD]

- Секреты (SUPABASE_SERVICE_ROLE_KEY, STRIPE_SECRET_KEY, RESEND_API_KEY, UPSTASH_*) — без префикса NEXT_PUBLIC_
- Только NEXT_PUBLIC_SUPABASE_URL и NEXT_PUBLIC_SUPABASE_ANON_KEY публичны

ULAGAT

Максимально полная техническая документация

2.5 «Периметр» (Nginx/TLS 1.3/Slowloris) [N/A — управляет Vercel]

TLS 1.3, защита от Slowloris/медленных атак, терминация PQC — это Vercel Edge (на базе Cloudflare). Своего reverse-проxy нет, конфиг Nginx писать некуда и не нужно. В нашей власти: HSTS+preload (есть), домен в hstspreload.org, «Attack Challenge Mode» при инциденте.

ULAGAT

Максимально полная техническая документация

14. DevSecOps аудит — Блок 3: безопасность будущего ИИ

Честно: в приложении сейчас нет ни одного ИИ-эндпоинта (в package.json нет @ai-sdk/anthropic/openai; ментор из плана не реализован). Prompt Injection/джейлбрейк/утечка системного промпта сейчас неприменимы — защищать нечего.

Готовый guard-модуль на момент, когда ИИ появится (не внедрять его без защиты):

```
// lib/ai/guard.ts — ■■■■■■■■■■ ■■ ■ ■■■■■■ ■■■■■■ ■■■■■■
const INJECTION_MARKERS = [/ignore (all )?previous instructions/i, ...];

export function sanitizeUserMessage(msg: string): string {
  // strip system-role markers, limit length, escape control chars
}
export function validateModelOutput(out: string): boolean {
  // ■■■■■■■■ ■■ ■■■■■■■■■■ ■■■■ ■■ ■■■■■■ ■■■■■■ ■■■■ sandboxing
}
```

Ключевые правила будущего ИИ (Defense in Depth):

- Никогда не подставлять user-message напрямую в системный промпт без разделителей
- Лимит через готовую таблицу ai_usage (question_count per user/day)
- RAG по архиву олимпиад — эмбединги pgvector, retrieval+цитаты, а не свободная генерация

ULAGAT

Максимально полная техническая документация

15. DevSecOps аудит — Блок 4: аутентификация и MFA

Честно про пароли: хеширование выполняет Supabase GoTrue (bcrypt), не наш код. Параметры Argon2id (memory/parallelism) недоступны на managed Supabase (только self-host). Правильные рычаги — ниже.

4.1 Leaked Password Protection [DASHBOARD]

Supabase Auth Passwords: Pwned Passwords / HaveIBeenPwned проверка + min length 10.

4.2 MFA TOTP для персонала [ОК, реализовано]

Самая рентабельная мера против захвата админ-аккаунта. Реализация:

```
// lib/security/mfa.ts
export async function mfaStepUpRequired(supabase): Promise<boolean> {
  const { data, error } = await supabase.auth.mfa.getAuthenticatorAssuranceLevel();
  if (error || !data) return false; // fail open — RLS ██████████ ██████████ ██████████
  return data.nextLevel === 'aal2' && data.currentLevel !== 'aal2';
}
```

Middleware редиректит на /admin/* /schedule/manage /schedule/substitutions /announcements/new /achievements/review при недостающем AAL2 /mfa?next=... Но middleware не покрывает POST на server actions напрямую — поэтому mfaStepUpRequired() встроен ВО ВСЕ 7 staff-гвардов (certificates, announcements, substitutions, schedule/manage, admin/actions, admin/users, achievements/review). Это закрывает обход, при котором украденная AAL1-сессия могла бы вызвать привилегированную мутацию, минуя страницу.

UI: components/settings/MfaSection.tsx — enroll/verify/unenroll флоу с QR-кодом через supabase.auth.mfa.enroll/verify/unenroll.
app/mfa/page.tsx — challenge-страница при входе в защищённую зону.

16. DevSecOps аудит — Блок 5: цепочка поставок и мониторинг

5.1 SCA в CI/CD [PATCH — применено]

- .github/dependabot.yml — авто-PR на уязвимые зависимости, еженедельно
- .github/workflows/security.yml — npm audit + запрет service-role в клиентском коде
- Политика: PR блокируется при уязвимости уровня high/critical
- npm ci с локфайлом (детерминированные сборки), периодически npm audit signatures

5.2 Структурные security-логи для SIEM [PATCH — применено]

Единый JSON-логгер критических событий без утечки PII (id вместо email, хеш вместо значения):

```
{
  "ts": "2026-07-05T10:00:00Z",
  "event": "suspicious_email_change",
  "user_id": "a1b2***",
  "ip_hash": "9f8e..."
}
```

Никаких паролей, токенов, полных email, тел писем. Вывод в stdout Vercel Log Drains SIEM/Datadog/Better Stack.

5.3 Чек-лист перед публичным релизом

- Supabase Advisors = 0 errors (варны разобраны: leaked-password protection, public_bucket_allows_listing)
- RLS на всех таблицах, проверено CI-запросом
- RLS/BOLA-рубеж, разделение ключей, cron-секрет, HSTS/заголовки, ограничение саморегистрации роли — [OK], проверены живыми атаками

ULAGAT

Максимально полная техническая документация

17. Реальный код: примеры из репозитория

17.1 Server Action с полной цепочкой защиты (requireStaff в substitutions/actions.ts):

```
async function requireStaff() {
  const supabase = await createClient();
  const { data: { user } } = await supabase.auth.getUser();
  if (!user) return { ok: false, error: "Not authenticated." };

  const { data: profile } = await supabase
    .from('profiles').select('role').eq('id', user.id).single();

  if (!profile || ![ 'admin', 'moderator' ].includes(profile.role))
    return { ok: false, error: "Unauthorized." };

  if (await mfaStepUpRequired(supabase))
    return { ok: false, error: MFA_REQUIRED_ERROR };

  return { ok: true, userId: user.id };
}
```

17.2 Защита от подмены пути в подписанной ссылке (certificates/actions.ts):

```
// Defense in depth: ■■■■■■■■■■ ■■■■ ■■■■■■■■■■ ■■■■■■■■■■
// ■■■■■■■■■■ ■■■■ ■■■■■■■■■■ – ■■■■■■■■■■ pdf_path ■■■■■■■■■■
// ■■■■■■■■■■ ■■■■ ■■■■■■■■■■ ■■■■■■■■■■.
const expectedPath = `${certRow.user_id}/${certRow.id}.pdf`;
if (certRow.pdf_path !== expectedPath) {
  console.error("path mismatch:", certRow.id);
  return { error: "Certificate file is unavailable." };
}
const { data } = await admin.storage.from('certificates')
  .createSignedUrl(expectedPath, 300, { download: `spravka-${id}.pdf` });
```

17.3 Race-guard на обновление статуса (защита от двойного одобрения):

```
const { data: updated, error } = await supabase
  .from('certificates')
  .update({ status: 'ready', pdf_path, processed_by, processed_at })
  .eq('id', id)
  .eq('status', 'pending') // <- ■■■■■: ■■■■ ■■■■■■■■■■ ■■■■ ■■■■■■■■■■, updated=[]
  .select('id');
if (error || !updated || updated.length === 0)
  return { success: false, error: "Failed to update the request status." };
```

17.4 Санитизация текста для PDF (посимвольная фильтрация control chars):

```
function clean(value: string): string {
  let out = '';
  for (const char of value) {
    const code = char.codePointAt(0) ?? 0;
    if (code < 0x20 || (code >= 0x7f && code <= 0x9f)) continue;
    out += char;
  }
  return out;
}
```

18. Миграции БД и переменные окружения

Ключевые миграции:

- **certificates_feature:** таблица certificates + RLS политики + приватный bucket
- **certificates_db_hardening:** CHECK на length(purpose) между 1-300, partial unique index (user_id, type) WHERE status='pending'

Обязательные переменные окружения:

Переменная	Описание
NEXT_PUBLIC_SUPABASE_URL	Адрес проекта Supabase
NEXT_PUBLIC_SUPABASE_ANON_KEY	Публичный ключ (браузер, ограничен RLS)
SUPABASE_SERVICE_ROLE_KEY	Сервер-ключ (PDF, email). БЕЗ ЭТОГО справки не сохраняются!
RESEND_API_KEY / RESEND_FROM_EMAIL	Отправка email (домен должен быть верифицирован)
UPSTASH_REDIS_REST_URL / _TOKEN	Rate-limiting (опционально, fail-open без них)
STRIPE_SECRET_KEY / STRIPE_WEBHOOK_SECRET	Платежи и верификация webhook

ULAGAT

Максимально полная техническая документация

19. Чек-лист перед релизом и roadmap

Готово к пилоту:

- ~90 компонентов, 26 server actions, 14 API endpoint, 33 таблицы БД
- Полная типизация (TypeScript), 230+ i18n ключей (RU/KK/EN)
- RLS проверен живыми атаками (adversarial DO-блок тесты) — включая 3 новые таблицы
- MFA (TOTP) на всех привилегированных действиях, не только на страницах
- Rate-limiting env-gated, fail-open по дизайну
- CSP ВКЛЮЧЕНА (enforcing) — проверено в браузере, 0 нарушений
- Глубокий многоагентный аудит (Opus 4.8): найдено и исправлено 3 бага

Операционные блокиеры (не код, действия пользователя):

- Добавить SUPABASE_SERVICE_ROLE_KEY в Vercel env (иначе справки не генерируются)
- Верифицировать домен в Resend (иначе email не отправляются)
- Внести реальное расписание школы в таблицу schedule
- Назначить роли персоналу (teacher/moderator/admin) вручную в БД
- Включить Leaked Password Protection в Supabase Dashboard

Отложено (записано, не в разработке):

- ИИ-ментор — требует платного LLM API, бюджет не выделен
- Бронирование пространств (Phase 9) — убрано из плана
- Self-hosted Supabase на K3 VPS — инфраструктурная задача, делается последней

Это единственный источник правды по проекту Ulagat на 7 июля 2026 г. Для деталей реализации — читайте код, каждая функция документирована типами и однострочными комментариями там, где не очевидна причина решения.

ULAGAT

Максимально полная техническая документация

20. Обновления (июль 2026)

Крупные подсистемы, добавленные после первой версии этого документа.

20.1 Лента достижений + реакции

Блок «Достижения школы» на /home (вечерний режим): последние verified-достижения всей школы. Реакции heart/clap кастомными SVG-иллюстрациями (не эмодзи). Таблица achievement_reactions (FORCE RLS: реагировать можно только от себя и только на verified-достижение; anon отозван). Приватность: leaderboard_anonymous теперь маскирует и ленту (псевдоним + маска, без ссылки).

20.2 СКУД-интеграция (вход/выход — только родителям)

Таблица skud_events. RLS: события видят ТОЛЬКО родители через family_bonds (+admin для отладки); ученик своих не видит, персонал — нет. Записи только service-role (политик записи нет). Webhook POST /api/skud/event: секрет x-skud-secret (timing-safe сравнение), лимит тела, 202 на неизвестную карту (нет оракула валидности). Ручной ввод для теста в /admin/users. Вкладка «Посещаемость» в профиле ребёнка — видна только связанному родителю, время в Asia/Almaty.

20.3 PWA push-уведомления

Устанавливаемое PWA: manifest.webmanifest, service worker (public/sw.js), иконки 192/512/maskable. Таблица push_subscriptions (owner-only RLS). Отправка через web-push (VAPID), env-gated (нет ключей тихо выключено) и fail-safe (сбой push не ломает операцию). События: объявления, справка готова/отклонена, напоминания о событиях — дополнительно к email. iOS доставляет push только установленному на домашний экран PWA (тумблер показывает инструкцию установки).

20.4 Безопасность: CSP enforce + фикс stored XSS

CSP переключён из Report-Only в ENFORCING (проверено в реальном браузере: логин рендерится и гидрируется, 0 нарушений). Добавлены worker-src 'self' (для service worker под strict-dynamic) и manifest-src. Введён safeHttpRequest() (lib/validation.ts) — блокирует javascript:ссылки на записи и рендере (achievement image_url, olympiad material url). Оба фикса нашёл глубокий многоагентный аудит (6 ревьюеров на Opus 4.8 + adversarial-верификация): 3 подтверждённых бага (2 stored XSS + гонка реакций) исправлены.

20.5 Улучшения существующих фич

- Лидерборд: подсветка себя, бейдж «Вы», карточка «ваша позиция» (#N из M) вне топ-10
- Расписание: прогресс-бар текущего урока/перемены, превью «далее: предмет», живой виджет теперь и на десктопе

Новые таблицы БД (15-17):

Таблица	Назначение и доступ
achievement_reactions	Реакции heart/clap на достижения (self + verified, FORCE RLS)
skud_events	События турникета — читают только родители через family_bonds (+admin)
push_subscriptions	Web Push подписки браузеров — только владелец (owner-only RLS)

Новые переменные окружения: NEXT_PUBLIC_VAPID_PUBLIC_KEY, VAPID_PRIVATE_KEY, VAPID_SUBJECT (push); SKUD_WEBHOOK_SECRET (турникет). Все опциональны — без них соответствующая фича тихо выключена.